

SCG remediation - Gemini Enterprise for CX - 2026-09-24

An external audit of the guide by ChatGPT, notes/Gemini-Ent-CX-GPT-Audit.md, was verified finding by finding and applied to _src/geminiCustomerExperienceGuidance.csv at the owner's direction ("Move forward based on best judgment"). **41 rows were revised and 3 added (IDs 1390, 1400, 1410); no ID was renumbered, merged, or retired.** The guide now holds 141 requirements across 12 categories. The pre-fix state is archived as _src/archive/geminiCustomerExperienceGuidance.2026-09-24.pre-audit-fixes.csv.

Method

The audit was treated as an external review: every claim was checked before anything was changed. Claims about the CSV were checked against the file. Claims about Google's documentation were checked against the live pages on 2026-09-24 by two independent agents, and the claims that drove a change were re-read directly: the IAM role reference for ces (parsed per role), the CX Agent Studio release notes, the WhatsApp and Instagram, A2A Protocol, Start with AI, SecuritySettings, settings, OpenAPI, MCP, and tools-overview pages, the model and guardrail pages, the RAG Engine overview, Google's HIPAA covered products list, eCFR, and the NIST SP 800-53 Rev. 5 OSCAL catalog. Edits were applied by a script that asserts each replaced passage matches exactly once, so no edit could land on stale text. The same validator as 2026-09-23 was then run, and every reference URL was fetched.

Verdict on the audit

The audit is sound. Of its 13 priority findings, 9 were confirmed in full and 4 in part; none was wrong. Two of them came from Google's 2026-09-24 release, which post-dates the 2026-09-23 update. Its weaker areas were its consolidation proposals, most of which conflict with the guide's standalone-row design and with a decision already recorded on 2026-09-23, and five findings that the current CSV already addressed.

Decisions recorded so they are not re-litigated

Pre-GA scope (ID 10). The baseline prohibition now covers production use and protected health information or other personal data. Evaluation of a Pre-GA feature is allowed only in a non-production project holding synthetic or otherwise non-personal data that shares no tool target, data store, service agent grant, or network path with production. This matches what IDs 30, 50, and 740 already assumed, and the Pre-GA terms, whose exposure comes from production reliance and regulated data. Where sources disagree on a launch stage, the more restrictive one governs, and a product-level GA announcement does not make the features it lists GA. The diff map marks ID 10 weakened so a change reviewer sees the narrowing.

WhatsApp and Instagram (new ID 1400). Not approved under this baseline. Google documents that only project owners can create the deployment, which conflicts with the basic-role prohibition (ID 130), and the channel routes member conversations through Meta outside Google's BAA. The prohibition lifts only when Google documents a path that does not need Owner and Meta has passed third-party review and, for PHI, has an executed BAA.

Third-party content in retrieval corpora (ID 400). Allowed only as a reviewed snapshot copied into organization-controlled storage, with each refresh reviewed as a new ingestion. Website data stores stay limited to organization-controlled domains.

OWASP LLM Top 10 edition. Not migrated this cycle. OWASP published a 2026 edition on genai.owasp.org on 2026-08-03, but its landing pages still present 2025, and a remap touches every LLM-mapped row. The 2025 labels are retained exactly, and the migration is an open workstream item.

No merges, again. The 2026-09-23 remediation recorded that merge suggestions are resolved by fixing the inconsistency rather than merging rows. The audit re-proposed one merge that decision already declined (690 with 820). The owner-facing analysis earlier in this session proposed merging 950 into 1220 and 1290 into 1260; both were withdrawn on finding the recorded decision. ID 950's inconsistency with ID 1220 (a SHOULD covering part of what a MUST already required) was resolved by raising ID 950 to MUST.

App Editor separation (new ID 1410). The IAM reference shows that `ces.apps.update`, which governs redaction, logging, export, and audio recording, is held by `roles/ces.appEditor` and `roles/ces.admin` and by neither `roles/ces.agentEditor` nor `roles/ces.toolsEditor`. Separating App Editor from the builder roles is therefore feasible, but it moves app creation and version creation off builders, so it is a SHOULD with a documented compensating control rather than a MUST.

Revision numbering. DocGen records `publish: false`, so the 2026-09-23 state was never published and 2026-09-24 is the same recertification cycle. Every row changed in the cycle carries its 2026-09-04 Revision plus one, whether it changed on 2026-09-23, 2026-09-24, or both; rows added in the cycle stay at 0. Four rows moved this session (490, 520, 810 to 2; 1220 to 1); 36 of the other changed rows were already incremented, and ID 1360, added this cycle, stays at 0. Result: 48 rows at Revision 2, 77 at Revision 1, 16 at Revision 0.

Diff map. One map for the cycle, as on 2026-09-23. `_src/geminiCustomerExperienceGuidance-diff-map-2026-09-23.csv` keeps its name, and each row changed today carries an "Audit fix (2026-09-24):" clause after its earlier notes. Totals: 89 corrected, 31 strengthened, 11 carried, 9 new, 1 weakened.

Disposition of the audit's priority corrections

IDs	Verdict	Action
320, 10	Confirmed	The Start with AI page carries a Preview banner and the Pre-GA terms; the 2026-02-04 note declares the product GA and lists the feature without calling it GA. ID 320's note corrected and its use confined to non-production on non-personal data; SA-11 removed; feature page cited. ID 10 gained the more-restrictive-stage rule.
10, 50, 740, 1270	Confirmed	ID 10 rescoped as recorded above; IDs 50, 740, and 1270 already conform and were not changed.
30	Partial	The Notes already conceded the inference. Rationale restated as organizational policy; detective query scoped to runtime principals, because administrative methods such as <code>UpdateSecuritySettings</code> are recorded under <code>v1beta</code> .
120, 140, 150, 160, 530	Confirmed, and wider than reported	The product access-control page prints <code>ces.googleapis.com/admin</code> ; the IAM reference uses <code>roles/ces.admin</code> and permissions such as <code>ces.tools.execute</code> . Normalized on 110, 120, 140, 150, 160, 500, 530, 730, and 1000; the audit missed 500, 730, and 1000.
110	Confirmed	Scoped to human user accounts; service identities governed by least privilege, no user-managed keys, and workload identity.
130, 150, 500, 580	Confirmed	New ID 1400 prohibits the channel; ID 130 states the Owner-only path is no exception; IDs 500 and 580 extended to WhatsApp, Instagram, and Meta. ID 150 needed only its role ID.

IDs	Verdict	Action
330, 360, 500, 590, 1220	Confirmed, and understated	Agent as a tool is now GA in Google's words (ID 330 corrected). A2A is Preview, so new ID 1390 prohibits it in both directions. ID 330 extends the delegation chain across projects; IDs 160, 500, and 590 bring inbound A2A callers under the client-role, channel-inventory, and gateway rules; ID 1220 names remote agents and transient caches.
140, 1120	Confirmed	SecuritySettings holds only the endpoint control policy. ID 140's rationale rewritten around egress; application settings named as governed by ces.apps.update; new ID 1410 separates App Editor. ID 1120 already reflected the split.
370	Partial	Only API keys are stored secrets; ID token and service account options are minted per call. Requirement scoped to static credentials; the undocumented OAuth secret storage is flagged.
380	Partial (ambiguity, not contradiction)	Rewritten so the tool may reach broader data only through backend object-level authorization against a session-bound identity; states that the product passes no end-user identity.
400	Confirmed	Resolved as recorded above.
500, 580	Confirmed	Fixed channel count replaced with a dated list and a reconciliation rule.
1180, 1190, 1200	Partial	The covered products list is flat and lists the suite itself, so ID 1190's "not named" test was undecidable. ID 1190 now requires coverage per component by its own entry or by written confirmation, and names Contact Center AI Platform. Not consolidated: the three rows test contract scope, component coverage, and API mapping separately.

Disposition of consolidation candidates

IDs	Disposition
20, 40, 50, 1270, 1320, 1350 under 10	Declined. Each has its own test surface (tool picker, model picker, use_gemini_asr in a conversation profile, Agent Assist feature table). ID 10 now calls for a Pre-GA register, which covers the audit's inventory point.
70, 1250	Declined; different triggers (new feature enablement versus a stage transition).
1260, 1270, 1290	Declined per the no-merge decision. ID 1260 gained the composite-v1 note; ID 1270's picker snapshot refreshed.
280, 290, 320	Kept separate as the audit advised; the suggested cross-reference from 280 to 320 was not added, because rows do not reference each other.
480, 1010	Declined; not duplicates. ID 1010 establishes Service Directory before the perimeter, and ID 480 routes OpenAPI, MCP, and five connector tools through it.
690, 820	Declined; already declined on 2026-09-23.
850, 860	No change; ID 850 is already the monitoring and multi-party row the audit asked for.
950, 1220	Not merged; ID 950 raised to MUST, and ID 1220's Notes name the transient stores.
1070, 1080	No change, as the audit advised.

IDs	Disposition
360, 490	Partly declined. The audit's premise that registration alone gives no access is wrong for this product: a Python code tool can call any tool defined in its application. Both rows now record that, and ID 360 inventories assignment as well as registration.
430, 450	ID 430's exclusivity claim replaced with the IAM caveat. ID 450 unchanged: its long Notes carry vendor-documentation inconsistencies the reviewer needs, and its transmission-security mapping fits a row about public egress.
340	CP-9 replaced with CM-2(3) Retention of Previous Configurations, with its parent CM-2; the audit's suggested controls were already present.
600	HIPAA 164.502(a) removed. The disclosure-timing wording was kept; "before conversation content is captured" is already testable.
1100	No change; the Notes already present six years as the organization's interpretation (fixed 2026-09-23).

Mapping and wording corrections applied

ID 300: ERISA citation qualified to ERISA-covered employee benefit plans, SI-18 removed, and the eCFR reference corrected to Subchapter G (Part 2560 sits in Subchapter G; the Subchapter F address redirects). IDs 630 and 710: AU-11 removed, SI-12 already present. ID 520: HITRUST 01.j and OWASP API2 replaced with 09.m and OWASP API6:2023, the abuse category reCAPTCHA addresses. ID 810: Notes now tie the 164.514(a) mapping to the rule that aggregates are not de-identified by default. IDs 890, 900, 940: HIPAA 164.530(j), left over from the 2026-09-23 fix that removed it from seven other rows, removed; ID 940's 164.504(e) replaced with 164.310(d)(2)(i) Disposal. ID 1150: AC-6(7) removed. ID 1170: 164.410 removed from Mappings; the Notes still explain Google's notification duty. ID 1240: NIST AI 100-1 cited for the inventory requirement (GOVERN 1.6). IDs 1360 to 1380: ID 1360 now states that a US region is not a residency commitment; IDs 1370 and 1380 already said what the audit asked for.

Not changed: ID 310, which already names California Business and Professions Code section 17941 and carries no URL because no allowed reference domain carries state law (decision of 2026-09-23); ID 540, whose 164.312(d) mapping covers entity authentication of the broker; ID 980, whose count of seven breakages is Google's enumeration.

Found beyond the audit

- **Inbound A2A is the larger exposure.** Inbound callers hold `roles/ces.client`, which includes `ces.tools.execute`, and can send `gecx_a2a_agent_context`, which the application writes directly into the session. Covered by new ID 1390 and by IDs 160, 330, 500, and 590.
- **ID 360's undocumented remote agent tool type** is now documented as the A2A Protocol tool; the note was replaced and the tool-type count moved from seventeen to eighteen.
- **composite-v1 (GA, 2026-09-24)** combines listener, thinking, and speaker sub-models whose minor versions Google may update automatically; ID 1260 now requires re-running voice evaluations at each monthly review.
- **ID 40's note** said every other tool type was GA; the A2A Protocol tool is now also Preview.
- **Supervisor agents (2026-09-24)** are audio-quality and missed-tool-call monitors that trigger guardrail outcomes. They are quality controls, not security controls, and no row was added; they fall under the monthly release review.
- **RAG Engine regions** were re-read: `us-east1` is still Allowlist, Preview, so ID 1360's basis stands. One verification agent had reported it as GA; the direct read corrected that.

Open items

- Ask Google for the launch stage of v1beta and v1alpha1 (ID 30).
- Ask Google where the OpenAPI and MCP OAuth option holds its client secret (ID 370).
- Decide when to migrate OWASP LLM mappings from the 2025 to the 2026 edition.
- Watch for a WhatsApp and Instagram creation path that does not need the Owner role (ID 1400).
- 19 reference URLs on `cloud.google.com` now redirect to the same page on `docs.cloud.google.com`, one of them to a changed path (`organization-policy/restrict-service-accounts`). All return HTTP 200; they were left as cited.

Verification

The CSV passed every generator Step 6 check with 0 errors, and all 104 distinct reference URLs returned HTTP 200 on 2026-09-24. See `notes/SCG-validation-2026-09-24.md`. The rendered guidance document was regenerated with the organization's template through `processDocs.py`, after first confirming that the same render of the pre-fix CSV reproduced the existing `_src/geminiCustomerExperienceGuidance.md` byte for byte.